

AR Match Pro — Release ARMP-2026.07.21-PILOT-AUTH-R3

AR Match Pro — Server-Controlled Pilot Access

Release ARMP-2026.07.21-PILOT-AUTH-R3 · Revised 2026-07-22 · Phase 3 (Supabase Auth + RLS + Edge Functions + TOTP MFA)

What this release is

R3 replaces the R2 client-side, format-only pilot code with **server-controlled pilot access**: Supabase Auth (email/password + mandatory TOTP MFA), PostgreSQL with Row-Level Security, and privileged Edge Functions administered through the ARMP Operations Console. Customer financial data continues to be processed **locally in the browser** and is never sent to Supabase.

Release status STAGING VALIDATION PENDING

- **Public website / Demo Mode:** may go to production after staging smoke testing. Demo Mode is synthetic-only.
- **Controlled real-data pilot: NOT approved** until the staging acceptance battery (migrations deployed, Edge Functions deployed, RLS, MFA, invitation flow, pilot date/suspension/revocation enforcement, organization isolation, data-boundary, and the 16-step E2E) passes against the supplied Supabase staging project **and** an independent review is complete.
- **Paid production: BLOCKED** pending independent security review, attorney-approved legal documents, cleared-funds activation, production Supabase project, production SMTP, backup/recovery validation, E&O/cyber insurance, approved incident response, and production monitoring.

Verified locally (this build)

- 12 migrations apply cleanly to real PostgreSQL 16; **RLS suite 26/26** on real Postgres.
- 20 Edge Functions type-check under Deno with real dependency resolution.
- Full JS battery **14 suites, 1,485 assertions** — including the **503 R2 assertions unweakened**, frontend-security, network-instrumented data-boundary, and R2-localStorage-cannot-grant-access suites.
- Expanded prohibited-pattern gate (context-aware; secret **values** vs variable **names**; `service_role` permitted only in backend).

NOT YET RUN / NOT VALIDATED IN STAGING

No Edge Function has executed against the live project; MFA, invitations, and session revocation are unproven until the 16-step staging E2E runs. Nothing has been deployed; the staging database is untouched; `main` is untouched; no secret appears in any file.

Deploy & test

Frontend: upload the contents of `deploy/` to Netlify staging (see ARMP_DEPLOYMENT). Backend: apply via the manual GitHub Actions workflows after owner approval (see ARMP_SUPABASE_OWNER_SETUP). Tests: `npm install && npm test`.